SOC L1 LAB · INC-005

Attack Setup Guide — INC-005

An outbound SYN sweep, its threshold, and the legitimate burst that crosses it

INCIDENT	INC-005 — Outbound port scan
REPORT DATE	2026-11-01
CLASSIFICATION	Lab exercise — sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	Medium

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. Authorization and safety
2. Topology and assumptions
3. Phase 0 — Verify the rule
4. Phase 1 — False-positive baseline (required)
5. Phase 2 — The scan
6. Phase 3 — Evidence capture
7. Phase 4 — Cleanup
8. Expected detections
9. Variations
10. Why this is realistic
11. Legal and ethical notes

A step-by-step script for reproducing INC-005 **inside the lab**. It is for testing detection and triage, not for use against systems you do not own.

---

1. Authorization and safety

Rule	Detail
Scope	Only the `soc-victim` VM and its QEMU gateway `10.0.2.2`
Never	Scan a LAN, an internet host, or an employer's network
Never	Use the lab rule as authorization for real scanning
Authorization	You own the host and the VM
Reversibility	No files are created; remove the local rule if desired
Rate	Keep scans local and short

The scenario models an internal host performing discovery. It does not exploit anything.

---

2. Topology and assumptions

```
Host 10.0.2.2  (QEMU gateway, few services)
  |
  |  outbound from the VM
  ▼
soc-victim 10.0.2.15
  Suricata on ens3
  HOME_NET 10.0.2.15/32
  local rule sid 1000001
```

Assumptions:

- Base lab from INC-001 is running.
- Suricata is active.
- `local.rules` contains sid 1000001 and is listed in `rule-files`.
- nmap is installed in the VM.
- Wazuh forwards Suricata alerts.

```
export LAB="$HOME/Documents/Eterna/soc-l1-lab"
export VMKEY="$LAB/lab/vm/keys/id_ed25519"
export VM="analyst@127.0.0.1"
export VMPORT=2222
```

---

3. Phase 0 — Verify the rule

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
systemctl is-active suricata
sudo grep -c "LAB SCAN" /var/lib/suricata/rules/local.rules
sudo grep -n "local.rules" /etc/suricata/suricata.yaml'
```

Expected: `active`, `1`, and `- local.rules` under `rule-files`.

If missing, follow the reproduction guide §2.

---

4. Phase 1 — False-positive baseline (required)

Normal traffic

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo apt-get update -qq >/dev/null 2>&1
curl -s -o /dev/null https://deb.debian.org/
curl -s -o /dev/null http://10.0.2.2:8080/'
sleep 8
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo grep -c "LAB SCAN" /var/log/suricata/wazuh.json 2>/dev/null || echo 0'
```

Expected: `0`.

40-request burst

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'for i in $(seq 1 40); do curl -s -o /dev/null http://10.0.2.2:8080/; done'
sleep 8
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo grep -c "LAB SCAN" /var/log/suricata/wazuh.json 2>/dev/null || echo 0'
```

Expected: `0`.

60-request burst

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'for i in $(seq 1 60); do curl -s -o /dev/null http://10.0.2.2:8080/; done'
sleep 8
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo grep -c "LAB SCAN" /var/log/suricata/wazuh.json 2>/dev/null || echo 0'
```

Expected: **10**. This is the false-positive boundary, not a bug. Record it.

---

5. Phase 2 — The scan

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo nmap -sS --top-ports 200 --min-rate 500 10.0.2.2 -oN /tmp/nmap-inc005.txt'
```

Expected: the gateway is mostly closed; port 8080 is open; the scan finishes in under a second.

Check the sensor:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo grep "LAB SCAN" /var/log/suricata/wazuh.json | tail -3'
```

Expected: alerts with `src_ip=10.0.2.15`, `dest_ip=10.0.2.2`, and many destination ports.

Check Wazuh:

```
docker exec single-node-wazuh.manager-1 sh -c \
  'grep "LAB SCAN" /var/ossec/logs/alerts/alerts.json | tail -3' \
  | jq -r '[.timestamp,.rule.id,.rule.description] | @tsv'
```

Expected: rule **86601**.

---

6. Phase 3 — Evidence capture

```
docker exec single-node-wazuh.manager-1 cat /var/ossec/logs/alerts/alerts.json \
  > /tmp/alerts_all.json

python3 - <<'PY'
import json, datetime
start=datetime.datetime.fromisoformat("2026-10-31T23:26:20+00:00")
end=datetime.datetime.fromisoformat("2026-10-31T23:28:00+00:00")
rows=[]
for line in open('/tmp/alerts_all.json'):
    try: a=json.loads(line)
    except: continue
    if a.get('agent',{}).get('name')=='soc-victim' and \
       start <= datetime.datetime.fromisoformat(a['timestamp']) <= end:
        rows.append(a)
json.dump(rows, open('docs/evidence/INC-005-alerts.json','w'), indent=1)
print(len(rows), "alerts")
PY

ssh -i "$VMKEY" -p "$VMPORT" "$VM" 'sudo cat /tmp/nmap-inc005.txt' \
  > docs/evidence/INC-005-scan.txt
```

---

7. Phase 4 — Cleanup

The scan leaves no files. The local Suricata rule can stay as part of the lab.

Remove it if you do not want it:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo rm -f /var/lib/suricata/rules/local.rules
sudo sed -i "/^  - local.rules$/d" /etc/suricata/suricata.yaml
sudo systemctl restart suricata'
```

There is no host state to revert.

---

8. Expected detections

Phase	Signal	Expected
Normal traffic	sid 1000001	0
40-request burst	sid 1000001	0
60-request burst	sid 1000001	10
nmap scan	sid 1000001	144 (first run)
Wazuh ingestion	86601	one alert per Suricata event
Host telemetry	5710/80792/FIM	none

---

9. Variations

9.1 TCP connect scan

```
sudo nmap -sT --top-ports 200 10.0.2.2
```

`-sT` completes the handshake and may not match `flags:S` the same way. Test whether the rule fires; it is a different scan shape.

9.2 Slow scan

```
sudo nmap -sS --top-ports 50 --scan-delay 500ms 10.0.2.2
```

Below 50 SYNs in 5 seconds, the rule stays silent. This is the documented evasion gap.

9.3 Single-port probes

```
for p in 22 80 443 8080; do nc -zv -w1 10.0.2.2 $p; done
```

A handful of connections is normal traffic, not a scan.

9.4 Inbound scan (optional bridge upgrade)

The host can reach only the VM's forwarded ports (`2222` , `8080`) over QEMU user networking. To scan the VM inbound, deploy the tap/bridge from the plan, put the VM on a routable segment, then scan `10.0.2.15` or the bridge address from the host. That is the better version of this scenario, and it requires privileged host setup.

---

10. Why this is realistic

- **Scans are cheap and common.** A compromised host often performs discovery first.
- **Direction changes detection.** An inbound-only ruleset misses outbound discovery.
- **Thresholds are trade-offs.** A load test looks like a scan at 50 SYNs/5 s.
- **Recon is not a breach.** The ticket must say what did not happen.

---

11. Legal and ethical notes

- Scan only the VM and its QEMU gateway.
- Do not reuse the rule or the commands against any other network.
- A scan can be an offence without authorization; the lab is the authorization boundary.
- Publishing the rule is fine; publishing a real target list is not.